AI Governance for Owner-Operator Firms

A Field Guide for the Founder Who Still Runs the Business

Boubacar Barry

Catalyst Works Consulting

April 2026

Foreword

This is a field guide for one specific person. Maybe you.

She runs a firm of forty people. A CPA practice in Salt Lake City. A regional law firm in Denver. A marketing agency that has grown faster than its operations.

She knows her firm cold. She knows where the margin lives. She did not start the firm to spend her Tuesday nights reading the EU AI Act. But the questions are arriving anyway.

Her associates are using ChatGPT for first drafts. Some paste in client information to make the output more relevant. Her CRM added an AI module last spring that was on by default. A vendor sent a contract amendment in August she did not read carefully. Her insurance carrier just added an AI questionnaire to her renewal. A prospective enterprise client asked, in a due diligence call, “what is your AI governance policy?” She did not have a good answer.

She is not behind. She is exactly where most firms her size are. The work has gotten ahead of the documentation.

This guide is short on purpose. Read it once. The goal is not to teach you to do the work alone. The goal is to give you a clear-eyed view of the work so you can decide what to do about it.

I am not a lawyer. I am not an auditor. I am not a CISO. I am the operator who has spent fifteen years inside firms like yours, watching the gap between what leaders know is happening and what they have written down. I have learned that most AI problems are not AI problems. They are clarity problems that AI has exposed.

Boubacar Barry April 2026

---

1. The CRM Already Decided

Most firms discover their first major AI exposure inside a tool they have used for three years.

The firm bought a CRM in 2022. Salesforce. HubSpot. Zoho. It worked fine. In late 2024 the vendor announced AI features. In early 2025 the features rolled out. Some required a click to enable. Some did not.

The “did not” category is where the trouble lives.

By spring of 2025, that CRM was reading every email between an account manager and a client. Summarizing the relationship. Drafting follow-up notes. Predicting deal velocity. Feeding all of it into the vendor’s models.

Most of those features are useful. None of that is the issue. The issue is that nobody at the firm decided to allow it. It was decided in a release note that the head of operations skimmed. It was decided in a terms-of-service amendment that arrived on a Friday afternoon in August. It was decided by the default setting on a feature toggle in an admin panel nobody had logged into in six months.

Multiply this by every piece of software the firm uses. Email platform. Marketing automation. Project management. Accounting. Time tracking. HR system. Each one of them has, in the last twenty-four months, added some form of AI. Some are summarizing your client communications. Some are using your data to train their models, and some are not.

The risk in 2026 is not what AI can do. It is what your team is already doing with it that nobody has written down.

The first job of governance is not to fix this. The first job is to see it.

---

2. The Twelve-to-Twenty Rule

A firm with twenty employees usually has between twelve and twenty AI tools touching the business.

The owner can typically name three.

Firm size	AI tools in stack	Tools the owner can name
20 employees	12 to 15	3
50 employees	15 to 20	3 to 5
100 employees	20 to 30	5 to 7
200 employees	30 to 50	7 to 10

The gap between the two columns is the diagnosis.

It is not a discipline problem. It is the natural drift of a fast-moving software market into a firm that runs on operating leverage. Vendors update terms. AI features get bundled. Defaults get flipped. The team adopts what works. The owner sees the financial statements, not the feature flags.

The fix begins with one ninety-minute meeting that owners never schedule until something forces them to.

What forces it: an insurance renewal questionnaire. A client due diligence call. A board member asking. A competitor incident in the news. A regulator with new authority.

The firms that handle AI well make the meeting happen before the trigger. The firms that handle it badly hold the meeting during the crisis.

---

3. The Three Surfaces

When something goes wrong involving AI inside a firm like yours, the source is almost always one of three places.

Shadow AI. Tools your team is using that nobody officially approved. Personal ChatGPT accounts. The free tier of Claude. A junior associate's Notion AI. Banning shadow AI without giving the team an approved alternative drives the use further underground. The shadow AI you cannot see is more dangerous than the shadow AI you can. Shadow AI is not a discipline problem. It is a workflow problem. The fix is a workflow.

Embedded AI. Software you bought before AI was a thing, that has since added AI features, often by default, often with vendor terms that allow training on your data unless you opt out within a window that has likely already closed. This is the largest surface in most firms. It is also the one nobody has thought about.

Vendor blindspots. The AI inside tools you have not bought yet but are about to. New AI procurement happens faster than legal review can keep up. A department head finds a tool. Runs a free trial. Signs a contract. The tool is in production before the firm has a record of approving it.

Three surfaces. Three different conversations. None of them require a CISO. All of them require the owner to know they exist.

---

4. The Fifteen Questions

Read these. Answer them honestly, in writing. The questions you cannot answer are the work.

Current AI usage

1. Walk through every AI tool your team uses on a regular basis, including tools built into software you already use. Can you name them all?
2. Are there tools your employees are using informally, outside of anything you have officially approved?
3. Which of these tools touches client data, employee data, or proprietary business information?

Risk exposure

4. If one of your AI tools gave a client wrong information or made a discriminatory decision, what would happen? Who would handle it?
5. If a client asked you today how you use AI and what data protections you have in place, what would you say?
6. Are any of your clients in regulated industries? Do you know if your AI use creates compliance obligations for them?

Existing policies

7. Do you have a written policy that governs how your team uses AI? Where does it live and when was it last updated?
8. What data are employees explicitly prohibited from inputting into AI tools?
9. If I asked one of your employees tomorrow what they are and are not allowed to do with AI, what would they say?

Stakeholder accountability

10. If something goes wrong with an AI system tomorrow, who is the first call? Who owns the response?
11. Who in your firm has authority to approve or reject the adoption of a new AI tool?
12. If a regulator or auditor asked you to demonstrate responsible AI use, could you produce evidence within 48 hours?

Vendor relationships

13. Have you read the AI-specific data provisions in your vendor contracts? Does your vendor use your data to train their models?
14. Do you have a list of AI vendors your team is approved to use? Who maintains it?
15. When you evaluate a new AI software vendor, what specifically do you ask about their AI practices?

If you answer all fifteen with specifics, your firm is in a small minority. Most firms answer three or four clearly. The rest land between “I think so” and silence.

The “I think so” answers are the dangerous ones. They mean the work has been started but not finished. Nothing is consistent. Nothing holds up under scrutiny. This is where most firms in your range live.

---

5. The One Question Most Firms Cannot Answer

Pick the AI tool with the most exposure. The one with the most client data. The most consequential outputs. For most firms it is the CRM or the email platform.

Ask the following question, out loud, in a meeting with the people responsible for that tool:

“If this tool produced an error tomorrow that affected a client, who is the first call?”

Three things happen.

The first thing: silence. People look at each other. The COO looks at the head of IT. The head of IT looks at the office manager who actually administers the tool. The office manager looks at the partner whose client was affected. Nobody answers.

The second thing: a half-answer. Someone says “well, it depends on what kind of error.” This is true. It is also a way of avoiding the question.

The third thing: a real answer. Eventually somebody says “I guess it would be me.” That answer, whatever it is, is the start.

A map of accountability is the document that turns those answers into a single page. Owner. Approver. First Responder. Three names per major AI tool. The whole map fits on one piece of paper.

The conversation that creates the map is the most uncomfortable conversation a firm has about AI. It is also the one that determines whether the firm is governed or just hopes to be.

---

6. The Policy That Gets Used

Most AI policies fail for one reason. They are written for a lawyer to defend, not for an employee to use.

The lawyer-defending policy reads like a treaty. It uses words like “shall” and “endeavor.” It defines AI in twelve clauses. It runs to fifteen pages. It is signed once, filed in a SharePoint folder, never read again.

The employee-using policy is two pages. Plain English. Specific to the firm. Seven categories: why the policy exists, risk classification, acceptable use, data handling, vendor procurement, human oversight, incident response. An associate can pick it up, read it in five minutes, and know what to do tomorrow.

The names are simple. The work is in the specifics. A risk classification system can be written in two paragraphs or twenty pages. The two-paragraph version is what gets used. The twenty-page version is what gets ignored.

There is a craft to writing the two-paragraph version that fits your firm. That craft is most of why owners hire help. Not because they cannot identify the seven categories. Because writing two pages an actual employee will follow takes more skill than writing fifteen pages that will impress a lawyer.

---

7. The Regulations You Already Live Under

The honest answer to "what laws apply to me?" is "more than you think and less than you fear."

Utah SB 149 (May 1, 2024). First US state law regulating private-sector use of generative AI. Applies to anyone using generative AI to interact with people in Utah, regardless of where the firm is located. Most Utah firms have not formally addressed it.

Texas TRAIGA, HB 149 (January 1, 2026). Civil penalties up to $200,000 per violation. The 60-day cure period is meaningful for firms with documentation of their governance practices.

Illinois HB 3773 (January 1, 2026). Prohibits AI in employment decisions in ways that discriminate. Requires disclosure when AI is used in hiring, promotion, or termination. If you use any AI tool in HR, this applies.

Colorado SB 24-205 (June 30, 2026, delayed). High-risk AI systems must use reasonable care to protect against algorithmic discrimination. The law is in flux. Stay informed.

EU AI Act. Banned practices enforceable since February 2025. Fines up to EUR 35M or 7% of worldwide annual turnover. If you serve any EU customers, this applies.

NIST AI Risk Management Framework. US federal voluntary guidance. Voluntary is a legal status, not a recommendation to skip it. The most defensible answer to "how do you govern AI?" points to NIST AI RMF.

A December 2025 executive order directed the Department of Justice to challenge state AI laws. The legal landscape may shift.

The firms that get this right do not chase regulations. They build a governance practice that works under any regulatory regime. The state laws change. The fundamentals do not.

---

8. What Insurance, Clients, and Auditors Are Asking

Regulations are slow. The pressure on firms is faster.

Insurance carriers. Cyber and professional liability carriers added AI questions to renewals in 2025. The questions are getting more specific each year. If the answer is no, your premium goes up.

If the answer is “yes, with documentation,” your premium does not.

Enterprise clients. Mid-market and enterprise procurement is adding AI to vendor due diligence. Sample question: “Have any of your AI vendors changed their data training policies in the last twelve months?” If you cannot answer in writing within forty-eight hours, you lose to the firm that can.

Auditors. The auditor’s question is simpler. “Show me your AI governance policy and the evidence that it is followed.” Firms that have a policy and three artifacts pass easily. Firms that have nothing fail.

The firms that do not get caught flat-footed did one thing right. They started the work before the trigger arrived. They wrote the policy in a calm quarter. They built the inventory when nothing was on fire. They named the accountabilities while everyone could think clearly.

This is the strongest argument for getting ahead of AI governance. Not the regulatory one. The operational one. The trigger is coming. The only question is whether your firm is ready when it arrives.

---

9. When You Need Help

Most of this work is doable inside the firm. Some of it is not. Honest decision criteria.

Run this work yourself if the AI footprint is small (under fifteen tools), you have a head of operations who can own the rollout, and you have legal counsel who can review the policy. If all three are true, this guide is enough.

Bring in a fractional advisor if the footprint is sprawling and getting harder to track, a client has asked about AI governance in due diligence, your insurance carrier added AI questions, you have employees in Utah / Texas / Illinois / Colorado, or the work has been on your to-do list for six months and not moved.

Hire a full-time CISO if the firm has crossed two hundred employees, the regulatory exposure is multi-jurisdictional and high-stakes, and the board is asking for a named accountable executive on AI.

The fractional model is the right scale for most firms in the twenty to two-hundred-employee range. Not because it is the most thorough. Because it is the right shape. You get an outside set of eyes and a working structure without the cost of a full-time hire.

---

10. What Changes When This Is Done Well

The owner walks into the next insurance renewal and gives the broker the document. The broker files it. Premium does not go up.

The managing partner gets the next enterprise due diligence call. She has the answer in writing. The contract closes faster.

The associate who used to paste client data into ChatGPT now uses an approved tool with a different default behavior. The data does not leave the firm. The output is roughly as good.

A board member asks a hard question about AI risk. The owner has a one-page answer. The board moves on.

A new AI vendor pitches the firm. The head of operations runs them through a one-page review. The contract gets signed in two days. The vendor knows the firm is serious about governance, and they bring their A-game.

None of this is dramatic. That is the point. AI governance done well is invisible. The conversations that used to derail meetings are now answered in advance. The small AI incidents that used to become big incidents now stay small.

The owner who has done this work feels different. Not relieved. Confident. The kind of confidence that comes from knowing exactly what is in the firm, who owns what, and what to say when somebody asks.

What to do next

If you want to walk through this for your firm specifically, the 20-minute AI Governance Assessment Call is on my Calendly. We map the biggest risk surfaces in your stack. No pitch. You decide on your own whether a deeper conversation makes sense.

https://calendly.com/boubacarbarry/ai-governance-assessment-call

For the deeper engagement: **bokar83@gmail.com**.

If you organize events for owner-operator leaders or professional services associations and want this material in front of your audience, the same email works. I speak on AI governance for firms in the twenty to two-hundred-employee range.

If you finish this guide and the work is clear, run it. Send me a note when you finish. The thing I learn most from is hearing how the patterns hold up against firms I have not worked with directly.

A closing observation.

The leaders who handle AI well in 2026 will not be the ones with the deepest AI knowledge. They will be the ones who got clear on three things early: what is in their stack, who is accountable, and how the firm decides.

None of those questions are technical. All of them are operational.

The firm that wins on AI governance is the firm that already operated well. AI just made the question of "how do you operate" impossible to avoid.

This is true in 2026. It will be true in 2030. It was probably true the whole time.

Boubacar Barry Catalyst Works Consulting April 2026

linkedin.com/in/boubacarbarry

This guide is a starting point for governance documentation, not legal advice. Any policy affecting employee rights, client data, or regulatory compliance should be reviewed by qualified legal counsel. The author is not a lawyer.

Free to share with attribution. Cannot be repackaged or sold.